

Payload — TryHackMe Writeup

Overview

This challenge focused on investigating a suspected **AI supply chain compromise** inside a production inference environment.

At **03:14**, the SOC detected outbound HTTPS traffic from the inference server to an unknown external address. No deployments were scheduled and no changes were logged, indicating a potential stealth compromise.

The objective was to analyze deployment logs, inspect production and staged models, identify malicious behavior, and recover the attacker's campaign flag.

Investigation

Deployment Timeline

The deployment logs revealed that the replacement model originated from a different organization than the original trusted source.

Question: What organization supplied the replacement model?

Answer:

trustworthy-ai-lab

Time Between Deployment and Detection

By comparing deployment timestamps with the SOC alert timestamp, the malicious model had been running undetected for:

21

days.

This indicates long-term persistence before detection.

Production Model Analysis

The production model was decompiled to inspect its serialized payload.

The malicious payload used the following Python function to execute shell commands:

system

This confirmed OS-level command execution capability.

Host Reconnaissance

The payload executed a shell command to capture host identity:

hostname

This allowed the attacker to fingerprint compromised systems.

Beacon Traffic

Network beacon logs showed outbound HTTP exfiltration activity.

HTTP Method Used:

POST

This indicates active data transmission to attacker infrastructure.

Candidate Replacement Model

Engineering had staged a replacement model (candidate_model.h5) but had not yet deployed it.

Running inspect_h5_model.py exposed a suspicious layer:

manipulate_output

This suggested the candidate model was also malicious.

Flag Recovery

The attacker split the campaign ID across multiple artifacts to avoid full detection.

Combining evidence from:

- beacon_capture.log
- Candidate model inspection

Recovered the full flag:

THM{b4ckd00r_1n_pl41n_s1ght}

Questions & Answers

Replacement organization

trustworthy-ai-lab

Days before detection

21

Payload execution function

system

Host identity command

hostname

HTTP method

POST

Suspicious candidate layer

manipulate_output

Flag

THM{b4ckd00r_1n_pl41n_s1ght}

Attack Chain Summary

1. Examined deployment logs to establish compromise timeline
 2. Identified suspicious model source organization
 3. Calculated dwell time before SOC detection
 4. Decompiled production model for malicious payload analysis
 5. Found OS command execution through serialized payload
 6. Analyzed outbound beacon traffic
 7. Inspected staged replacement model for additional compromise
 8. Combined artifacts to recover campaign flag
-

Severity

Critical — The production model contained an active backdoor capable of command execution and outbound exfiltration, representing a severe AI supply chain compromise.